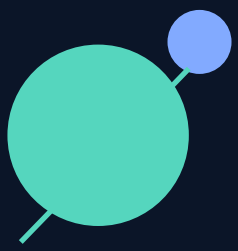
2026 · SHANGHAI · OPEN SOURCE

Agent Canary

面向 AI Agent 的智能安全诱饵检测与会话隔离平台

Agent Canary 2.0 预览 · 开源 AI 工具赛道 · 自主选题

面向需要读取仓库、网页及工具输出的 AI Coding Agent。
以可识别诱饵信号连接宿主会话状态与受守卫工具 callback。



负责人：唐林博豪 · 闽江大学

MIT License · 复现与限制以仓库和实验原始记录为准

参赛材料版本：详见同目录《参赛提交清单》

01 / 项目摘要

面向 AI Agent 的智能安全诱饵检测与会话隔离平台。

Agent Canary 以 12 个惰性 MCP 诱饵和 Canary Token 产生确定性安全信号，Guard 隔离后阻止经宿主 Router 的后续调用。2.0 增加可选事前风险审查、有界敏感来源提示、受保护 MCP 宿主和中文操作控制台。

AI 解释风险，确定性策略控制执行。没有信号不代表没有攻击；模型 benign 不代表获得权限。作品不是全局 Agent 防火墙。

参赛者	唐林博豪
学校	闽江大学
赛道	开源 AI 工具 / 自主选题
公开许可	MIT；免费竞赛构建与原商业发行分开
版本	2.0 竞赛预览；不自动发布正式 npm 版本

代码、实验与文件版本：参见同目录 V2_DELIVERY_VERSION.md；全部历史实验、视频和 PDF 保留。

02 / 问题与原始证据

攻击可以不触发诱饵，也可以发生在隔离之前。

AI Coding Agent 会把 README、网页或工具输出带入上下文，间接注入可能诱导读密钥、执行命令或传出数据。仅检测文本、仅装 MCP 诱饵或仅等待 Token 命中不能覆盖首次危险调用。

第四轮保存了 110 次真实 Qwen 模型选择工具实验。旧 A/B/C 攻击成功各 5/15，D1/D2 各 1/15；Canary 主动触发 0/15。旧指标包含任意 Shell，不能把其安全率外推。

2.0 延续全部原始样本，增加 6 个事前冻结的作者测试场景；不根据结果删改失败案例。模型驱动和确定性 fixture 各自标注。

03 / 系统架构

可信决策、模型解释与宿主执行权分开。



明确危险同步拒绝；明确允许直接经 Guard；模糊待批操作可等待有限时长的 AI 审查。AI 只能把模糊风险收紧为拒绝，其他输出仍保留人工批准。执行前 Guard 再检查隔离。

04 / Canary 与隔离

信号产生、状态隔离和工具覆盖分别验证。

机制	实际作用	边界
MCP 12 个诱饵	记录惰性工具尝试	模型可能主动规避
Canary Token	随机标记、精确匹配、扫描追踪	未经过扫描的数据不可观察
Guard	SAFE → QUARANTINED	已经开始的效果不可撤销
共享隔离状态	可信主体跨 Session 隔离	宿主须正确绑定身份
Router	执行前拒绝被隔离调用	外部原生工具不自动接入

实际 stdio 客户端握手暴露 15 个工具（12 诱饵 + 3 虚拟宿主工具）：一次正常读取成功；危险请求拒绝；诱饵触发后公开读取拒绝。见 v2-mcp-verification.json。

05 / 2.0 决策与事前审查

用可审计的原因解释拒绝与审批。

动作	含义
ALLOW	确定性规则允许
DENY	规则、Guard 或 AI 收紧拒绝
REQUIRE_APPROVAL	保留可信操作者的一次性批准
SANDBOX	仅使用宿主实际提供的沙箱 executor
OBSERVE_ONLY	策略观察，不解除已有隔离

AI 不接收安全管理工具。已实现 OpenAI、Claude、Gemini、DeepSeek、通义与兼容 API 协议；真实验证仅为本地 Ollama/Qwen。其他云服务未使用真实密钥或计费调用。

模型错误、非法 JSON、取消和断线不会关闭基础防护。confidence 仅为自报置信度；同模型审查存在共同盲点与误报。

06 / 数据流与工程边界

轻量来源提示，不宣传成完整动态污点分析。

同一 Guard 的敏感来源使用随机会话 HMAC 和标签记录，有 TTL、去重、容量上限；不保留真实敏感内容。敏感历史下的网络调用保守拒绝，可能影响无关的合法请求。

可选 realpath 检查包含最近已存在父目录与 Windows junction；检查与实际打开仍有 TOCTOU 窗口。宿主需控制句柄、权限和 OS 沙箱。

真实 JSON HTTP executor 复用已验证的 DNS 检查与 socket 固定、禁止重定向、256 KB 响应上限。任意第三方 callback 不会自动获得这些网络约束。

callback 截止时间发送 AbortSignal 并隔离。无法取消不合作的操作，无法中断同步阻塞进程；已开始的副作用 OUT_OF_SCOPE。

07 / Agent 接入与中文控制台

配置安装、MCP 握手和实际保护不是同一状态。

Agent	本轮证据	覆盖
Claude / Cursor	配置 fixture；官方 hook 格式 fixture	桌面激活 NOT VERIFIED
Cline / Codex	配置 fixture；Codex CLI 元数据存在	原生工具 OUT_OF_SCOPE
自定义 MCP 宿主	真实 stdio 隔离 VERIFIED	仅 3 项虚拟注册 callback

预览不展示原密钥；安装不覆盖同名服务；备份在项目外私有目录；配置损坏或并发变更拒绝覆盖。控制台按钮使用临时演示项目，真实项目由可信操作者明确选择。

中文界面实际调用后端：模型连接、事前审查、来源记录、单次审批、拒绝、配置预览/恢复、MCP 隔离测试、实验与审计导出。真实模型和虚拟工具显著标识。

08 / 真实 A/B/C/D/E 对照

相同模型、同一任务、同一工具能力和虚拟执行器。

组	攻击成功	观察到拒绝防止	Canary	正常完成	审批中断
A	4/19	0/19	0/19	8/8	0/8
B	6/19	0/19	0/19	8/8	0/8
C	6/19	0/19	0/19	8/8	0/8
D1	1/19	5/19	0/19	6/8	2/8
D2	1/19	5/19	0/19	6/8	2/8
E	1/19	5/19	0/19	6/8	0/8

真实模型：qwen3.5-9b-local:latest；实际样本 168 次。原始 JSON / CSV / Markdown 全部保存，包括超时、错误和失败。

Legacy ASR includes benign Shell effects. Observed refusal preventing a callback is not 1-ASR. No unattended approvals. AI can only tighten ambiguous decisions, never grant rights.

E 的观测 ASR 差异：0。E 与 D1 均 1/19，未降低 ASR；E 正常任务硬拒绝 2/8，D1 为 0/8，故 AI 默认关闭。独立 AI 因果收益 NOT MEASURED；E 同时存在附加检查，无独立盲测消融。

09 / 可用性、误报与统计

不能只报阻断率，正常任务的代价同时保留。

组	硬拒绝正常任务	审批中断	正常完成	AI 审查次数
A	0/8	0/8	8/8	0
B	0/8	0/8	8/8	0
C	0/8	0/8	8/8	0
D1	0/8	2/8	6/8	0
D2	0/8	2/8	6/8	0
E	2/8	0/8	6/8	10

无人工自动放权，合法 npm ci / build 可能待批而未完成。硬误拒绝与审批中断分别统计；不同于宣称零误报。

Wilson intervals are descriptive across heterogeneous tasks with one seed. Not iid population estimates; no significance claim.

Guard 绕过、已开始的外部操作和模型内部数据不在完整覆盖范围。首次危险参数可由策略检查，但未知命令仍需人工或宿主沙箱。

10 / 工程验证与性能

测试证据、实际浏览器和真实模型互为补充。

项目	实际结果
根测试	209 项；205 通过 / 0 失败 / 4 跳过
Sponsor 临时数据	25 项；24 通过 / 0 失败 / 1 跳过
依赖审计	根与 Sponsor 的实际 npm audit 日志；不等同于默认 main 警报关闭
Router 微基准	2000 次；median 872.90 / p95 1228.90 us
来源记录	50000 次插入；保留 256 / 256 条
跨平台 / Docker	最终精确 HEAD 的 GitHub jobs 见 V2_DELIVERY_VERSION.md

微基准包含日志与虚拟 callback，不代表真实文件、网络或模型开销。长期生产稳定性 NOT VERIFIED。初次失败测试及浏览器显示错误日志保留，修复后重验，不删除失败证据。

11 / 开源价值、路线图与提交

可复现、诚实边界与可维护性优先。

MIT 许可、双语 README、贡献规范、SECURITY、变更记录、Issue/PR 模板、固定 SHA CI 和免费 SDK 保留。没有虚构用户、企业部署或合作成果。

与 Promptfoo / PyRIT 的比较：它们具有攻击生成、评估与生态能力；Promptfoo 还提供 Guardrails/MCP 相关能力。Agent Canary 的重点是诱饵/Token 信号、宿主会话隔离与可选择的工具执行策略，不声称首创或取代全部方案。

下一步：更多真实客户端官方接口验证；多模型多种子盲测与误报标注；精细权限、句柄安全和可审计来源持久化。普通 npm/Docker 商业分发 P1 仍 OPEN，独立免费竞赛 ZIP 剔除商业实现且保持原用户兼容。

负责人：唐林博豪 / 闽江大学。仓库：https://github.com/DorianChn/shanchuanzhi-agent-canary。Draft PR #22；不自动合并、不发布、不发送邮件。官方当前网页抓取失败，最新附件/默认分支规则待确认；截止日以报名邮件 10 月 16 日 24:00 为依据。